GDPR For Indie Hackers Cheat Sheet

6 printable pages of the actual GDPR compliance program you need to ship in 30 days. Pin the 1-pager to your wall. Use the tracker every week. Stop "we'll add it later" and start shipping.

Page 1 -- The Six Documents (wall poster)

The only six GDPR documents a solo founder needs to sell to EU customers without getting fined.

- 1. **Privacy Policy.** Public page. What data, why, how long, who you share with, how to request deletion. Don't write from scratch -- use a generator.
- 2. **Data Processing Agreement (DPA).** Contract for every customer who is a "data controller." Required by Article 28.
- 3. **Data Flow Diagram.** One page. Where data enters, where it lives, where it leaves, who has access.
- 4. **Record of Processing Activities (ROPA).** Spreadsheet of every data category, lawful basis, retention, security measures. Required by Article 30.
- 5. **Sub-processor list.** Public page of every third party that touches customer data. Each one needs its own DPA.
- 6. **Breach response runbook.** One page. Who to call, who notifies the regulator (72h), who notifies customers.

If you have these six documents and they're current, you can pass an EU enterprise security review. Everything else is decoration.

Page 2 -- The 30-Day Calendar

Week	Action	Owner	Done?
1	Privacy Policy + DPA published	Founder	[ ]
2	Data Flow Diagram + ROPA	Founder + Eng	[ ]
3	Sub-processor DPAs + Breach Runbook	Founder	[ ]
4	Test with EU customer persona	Founder	[ ]

The hardest day is day 21. That's when you realize you have 12 sub-processors and you've only got DPAs for 3. Spend one afternoon fixing it. Auditors accept "DPA in place" if you have a date for it.

Page 3 -- Weekly GDPR Checklist

Print this. Every Friday, walk through it. 10 minutes. That's the whole program.

```
Friday GDPR Check (10 min)
--------------------------
[ ] Any new vendors touching customer data? DPA in place?
[ ] Any new cookies/tracking? Consent banner updated?
[ ] Any new email lists? Double opt-in enabled for EU users?
[ ] Any new data categories? Update ROPA.
[ ] Any deletion requests pending? Process within 30 days.
[ ] Any export requests pending? Process within 30 days.
[ ] Quarterly access review? (only on last Friday of quarter)
[ ] Any data breach or near-miss? Update incident log.
```

Done. That's the whole Friday ritual. EU regulators love seeing this checklist completed weekly.

Page 4 -- Data Subject Request Workflow

```
DATA SUBJECT REQUEST (30-day SLA)
---------------------------------
Type:       [ ] Access  [ ] Deletion  [ ] Export  [ ] Correction
Received:   _____ (date)
User email: _____
Channel:    [ ] Email  [ ] In-app  [ ] Support ticket

STEPS:
[ ] Verify identity (ask for account email + last 4 of payment card,
  or equivalent). Don't process until verified.
[ ] Export the user's data from production DB, analytics, backups (eventually).
[ ] For deletion: also delete from sub-processors (Stripe, email tool, etc.)
[ ] For deletion: anonymize instead of delete where records must be kept
  (financial transactions, tax records -- see your accountant).
[ ] Confirm completion via email to the user.
```

[ ] Log: "DSR [type] for [user-hash] completed on [date] by [initials]."

[ ] File the log entry. Required for audits.

If you can't complete in 30 days, email the user with the reason and

a new deadline. Regulators want to see the attempt, not the silence.

```

**Why this matters:** Every SaaS gets these requests. Most ignore them. The 4% of revenue fine starts with a regulator seeing a pattern of ignored requests. Process them. Every one. On time.

---

## Page 5 -- The Sub-Processor DPA Checklist

```

SUB-PROCESSOR DPA TRACKER

For every vendor that touches personal data:

[ ] AWS   DPA in AWS console (default, check it)

[ ] Stripe   DPA at stripe.com/legal/dpa

[ ] OpenAI / Anthropic DPA at their legal pages

[ ] Your email tool   (ConvertKit, Mailgun, Postmark -- all have DPAs)

[ ] Your analytics tool (Mixpanel, Amplitude, PostHog)

[ ] Your error tracker   (Sentry, Bugsnag, Rollbar)

[ ] Your hosting   (Vercel, Netlify, Render -- all have DPAs)

[ ] Your database   (Supabase, PlanetScale, Neon -- all have DPAs)

[ ] Customer support tool (Intercom, Crisp, Help Scout)

[ ] Anything else?   _____

```

**The 80/20 here:** the 8-10 vendors above cover 80% of typical SaaS. The remaining 20% are usually low-risk (e.g., your uptime monitor) but list them anyway.

**Update this within 30 days of adding a new sub-processor.** Some customer contracts require it. Auditors check the dates.

---

## Page 6 -- The Breach Response 1-Pager (laminate this)
```

```
BREACH RESPONSE -- 1 page
------------------------
- 1. DETECT     Customer report, monitoring alert, security researcher
       Time-stamp the report. Create #breach channel.
- 2. CONTAIN    Stop the bleeding. Disable the affected system
       or feature. Preserve logs. Do not delete anything.
- 3. ASSESS     Is this personal data? Is it EU residents? How many?
       If yes to both -> regulator notification required.
- 4. NOTIFY     Regulator: within 72h of detection.
       Customers: ASAP, with what you know + what you're doing.
- 5. ERADICATE  Patch the vuln, revoke the token, fix the misconfig.
- 6. RECOVER    Verify the fix. Re-enable. Monitor for 30 days.
- 7. POST-MORTEM  Within 10 business days. Blameless. Document
       what broke, what worked, what to change.

Breach Lead:       _____ (probably you)
Regulator contact: _____ (your local DPA)
Customer comms:    _____ (your support email)
Legal contact:     _____ (your lawyer, or one you need)

If in doubt, notify. The fine for over-notifying is zero.
The fine for under-notifying is up to 2% of revenue.
```

This is the only page you actually need during a breach. Keep it on your desk. The other 5 pages are for the Friday ritual.